

History of IT audit

The field of IT audit originated in the 1960s when businesses began using computers for financial data processing, raising concerns about data integrity and system reliability. Early audits focused on evaluating mainframes and ensuring compliance with manual control frameworks.

As networks grew in the 1980s and 1990s, IT auditors shifted their focus to security, particularly network security, data privacy, and disaster recovery. Key public cybersecurity disclosures, such as the Morris Worm (1988) and Melissa Virus (1999), highlighted the vulnerabilities in digital systems, driving IT audit practices to address evolving threats.

By the 2000s, the IT audit profession expanded significantly, addressing compliance with regulations like SOX (2002) and GDPR (2018). Today, IT auditors focus on governance, risk management, and controls over cloud computing, AI, and cybersecurity frameworks.

Key Cybersecurity and IT Audit Standards (Chronological Order)

This section provides a comprehensive list of key guides and standards that have shaped the fields of IT audit and cybersecurity.

1. BS 7799 (1995)

- Issuance Body: British Standards Institution (BSI)
- Scope: Information security management.
- Methodology: Provided a framework for implementing security controls within organizations.
- References: Predecessor of ISO 17799 and ISO 27001.

2. COBIT 1.0 (1996)

- Issuance Body: ISACA (Information Systems Audit and Control Association)
- Scope: IT governance and management.
- Methodology: Focuses on aligning IT with business goals and managing IT risks.
- References: Used by auditors to assess IT control environments.

3. ISO/IEC 17799 (2000)

- Issuance Body: International Organization for Standardization (ISO)
- Scope: Information security best practices.
- Methodology: Focuses on securing information through a comprehensive set of security controls.
- References: Evolved from BS 7799.

4. ITIL v2 (2001)

- Issuance Body: UK Government's Central Computer and Telecommunications Agency (CCTA)

- Scope: IT service management framework.
- Methodology: Emphasizes delivering high-quality IT services through best practices.
- References: ITIL is widely adopted by organizations to manage IT services.

5. Sarbanes-Oxley Act (SOX) (2002)

- Issuance Body: U.S. Congress
- Scope: Financial reporting and corporate governance.
- Methodology: Imposes requirements for internal controls, including IT systems supporting financial reporting.
- References: IT auditors focus on controls over financial systems.

6. ISO/IEC 27001 (2005)

- Issuance Body: ISO
- Scope: Information security management system (ISMS).
- Methodology: Risk management-based approach to securing information assets.
- References: The global standard for ISMS certification.

7. PCI DSS (2006)

- Issuance Body: Payment Card Industry Security Standards Council
- Scope: Payment card security.
- Methodology: Establishes security requirements for organizations that handle credit card information.
- References: Widely used in financial and retail sectors.

8. NIST Special Publication 800-53 (2009)

- Issuance Body: National Institute of Standards and Technology (NIST)
- Scope: Security and privacy controls for federal information systems.
- Methodology: Provides a catalog of controls to protect information systems.
- References: Mandatory for U.S. federal agencies.

10. NIST Cybersecurity Framework (2014 & 2024)

- Issuance Body: NIST
- Scope: Cybersecurity risk management.
- Methodology: Focuses on identifying, protecting, detecting, responding to, and recovering from cyber threats.

- References: Widely adopted by organizations worldwide.

9. GDPR (2018)

- Issuance Body: European Union
- Scope: Data protection and privacy.
- Methodology: Requires organizations to protect personal data and report breaches.
- References: Influences global data privacy practices.

11. ISO/IEC 27701 (2019 & 2022)

- Issuance Body: ISO
- Scope: Privacy information management system (PIMS).
- Methodology: Extends ISO 27001 to include privacy controls.
- References: Useful for organizations seeking to comply with GDPR.

12. CCPA (California Consumer Privacy Act) (2020)

- Issuance Body: State of California
- Scope: Data privacy rights for California residents.
- Methodology: Requires businesses to disclose data collection practices and give consumers control over their personal data.
- References: Similar to GDPR but specific to California.

Evolution of Financial Audit Standards with IT/InfoSec Aspects

1. Generally Accepted Auditing Standards (GAAS) (1939)
 - Introduced by the American Institute of Accountants, GAAS initially focused on traditional financial audits.
2. Internal Control - Integrated Framework (COSO) (1992)
 - Developed by the Committee of Sponsoring Organizations (COSO), this framework emphasized internal controls, including IT systems.
3. SOX (2002)
 - The Sarbanes-Oxley Act brought IT systems under scrutiny by requiring internal controls for financial reporting, including IT controls.
4. International Standards on Auditing (ISA) 315 and 330 (2009)

- These standards introduced guidance on auditing IT systems as part of financial audits.
5. AICPA Trust Services Criteria (2017)
- Developed by the American Institute of Certified Public Accountants (AICPA), these criteria focus on IT controls in service organizations.

This comprehensive list outlines how both IT audit and cybersecurity standards have evolved to address the growing importance of digital security and compliance.